

PROJECT 3: HOME SIEM LAB

Project Overview

Difficulty: Intermediate

Time: 16-20 hours over 2 weeks (2-3 hours/day)

Build During: Weeks 5-6, after Security+ exam

Build a functioning Security Information and Event Management (SIEM) system. Collect logs from multiple sources, create detection rules, simulate attacks, and investigate alerts like a real SOC analyst.

Tech Stack (All Free, Mac-Compatible)

- **Virtualisation:** UTM or VirtualBox
 - **SIEM:** Wazuh (free, open-source) or Splunk Free (100MB/day limit)
 - **Log Sources:**
 - Ubuntu Server (Wazuh agent)
 - Windows 10 VM (Sysmon + Wazuh agent)
 - pfSense firewall logs (if you completed Project 1)
 - **Attack Simulation:** Atomic Red Team or manual techniques
-

Learning Objectives

Technical Skills:

- Deploy and configure a SIEM platform
- Install agents on endpoints for log collection
- Configure log forwarding and parsing
- Create detection rules for common attacks
- Investigate alerts and create incident timelines
- Build dashboards for security monitoring
- Tune rules to reduce false positives

Security Concepts:

- How SIEMs aggregate and correlate logs

- Event correlation across multiple sources
- Detection engineering (writing rules)
- Alert triage workflow
- Incident investigation methodology
- Balance between detection coverage and false positives

Interview Ammunition:

- "Have you used a SIEM?" → Yes, deployed Wazuh/Splunk and configured it
 - "Walk me through investigating an alert" → Reference your actual investigations
 - "How do you write detection rules?" → Show rules you created
 - "How do you handle false positives?" → Discuss your tuning process
-

What You'll Build

Functioning SIEM Environment:

- Wazuh/Splunk server collecting logs
- 2+ endpoints sending logs (Windows, Linux)
- 5+ custom detection rules
- Dashboards showing security metrics
- 5+ documented investigations

Documentation:

- SIEM architecture diagram
 - Detection rule library with justifications
 - Investigation playbooks
 - False positive tuning notes
 - Dashboard designs
-

Build Phases

Phase 1: Deploy SIEM Platform (Days 1-3, 6 hours)

Choose Your SIEM:

Option A: Wazuh (Recommended)

- True security SIEM with built-in rules
- Better for learning SOC work
- Built-in vulnerability detection
- Active community

Option B: Splunk Free

- Industry standard
- 100MB/day log limit (enough for home lab)
- Great for resume/CV
- Lots of tutorials available

Deployment:

1. Create Ubuntu Server VM (4GB RAM, 40GB disk)
2. Install Wazuh Manager or Splunk
3. Access web interface
4. Complete initial configuration

Read First:

- Wazuh: documentation.wazuh.com/current/installation-guide
- Splunk: docs.splunk.com/Documentation/Splunk/latest/Installation

Deliverable: Screenshot of SIEM dashboard, confirm you can log in

Phase 2: Deploy Log Sources (Days 4-6, 6 hours)

Create Endpoint VMs:

Windows 10 Endpoint:

1. Create Windows VM (4GB RAM)
2. Install Sysmon (enhanced Windows logging)
3. Install Wazuh agent pointing to SIEM
4. Verify logs arriving in SIEM

Ubuntu Endpoint:

1. Create Ubuntu VM (2GB RAM)
2. Install Wazuh agent
3. Configure log collection
4. Verify connectivity

Key Learning: Agents collect local logs and forward to SIEM. SIEM needs to parse different log formats.

Verification Checklist:

- ☐ Can see Windows events in SIEM
 - ☐ Can see Sysmon events (Process Creation, Network Connection)
 - ☐ Can see Linux auth logs
 - ☐ No agent connection errors
-

Phase 3: Create Detection Rules (Days 7-10, 8 hours)

Write 5 Detection Rules:

Rule 1: Failed Login Brute Force

- Trigger: 10+ failed logins to same account within 5 minutes
- Log source: Windows Event ID 4625
- Why: Detect password attacks

Rule 2: New User Account Created

- Trigger: Windows Event ID 4720
- Log source: Windows Security logs
- Why: Detect unauthorized account creation

Rule 3: Suspicious PowerShell Execution

- Trigger: PowerShell with encoded commands
- Log source: Sysmon Event ID 1 (Process Creation)
- Why: Malware often uses encoded PowerShell

Rule 4: Connection to Known Malicious IP

- Trigger: Network connection to IP on blocklist

- Log source: Sysmon Event ID 3 (Network Connection)
- Why: Detect C2 communication

Rule 5: File Downloaded from Internet

- Trigger: Browser process writes .exe to Downloads
- Log source: Sysmon Event ID 11 (File Creation)
- Why: Detect potentially malicious downloads

For Each Rule Document:

- Rule name and description
- Logic (what triggers it?)
- Why is this important?
- Expected false positive rate
- How to investigate when it fires

Key Learning: Writing rules = balancing detection vs noise. Too sensitive = alert fatigue. Too loose = miss attacks.

Phase 4: Simulate Attacks & Investigate (Days 11-14, 10 hours)

Run 5 Attack Simulations:

Simulation 1: Brute Force Attack

- On Windows VM, attempt many wrong passwords
- Check SIEM for failed login alerts
- Investigate: Who, when, from where, successful?
- Document investigation steps

Simulation 2: Create Unauthorized Account

- Create new user account on Windows
- Check SIEM for account creation alert
- Investigate: What account, who created it, when, privileges?

Simulation 3: Run Suspicious PowerShell

- Execute encoded PowerShell command

- Check SIEM for PowerShell alerts
- Investigate: What command, what did it do, IoCs?

Simulation 4: Download Suspicious File

- Download test .exe from internet
- Check SIEM for file creation alerts
- Investigate: What file, from where, executed?

Simulation 5: Network Reconnaissance

- Run nmap scan from one VM to another
- Check SIEM for scanning indicators
- Investigate: Who scanned, what was discovered?

For Each Investigation Create:

- Alert description
 - Investigation methodology
 - Timeline of events
 - Findings and evidence
 - Assessment (true positive? false positive?)
 - Recommendations
-

Key Challenges & Learning Moments

Challenge 1: "Too many alerts, I'm drowning!"

- This is real SOC life
- Learning: Tune rules, whitelist known-good activity, prioritize by severity

Challenge 2: "Rule isn't triggering when it should"

- Check: Is agent sending logs? Is log format parsed correctly? Is logic correct?
- Learning: Troubleshooting detection rules is common SOC work

Challenge 3: "Everything triggers the rule, too many false positives"

- Add context: Time of day, specific users, specific processes

- Learning: Good rules have context, not just "if X then alert"

Challenge 4: "I don't know if this alert is real or not"

- Investigate: Check what else the user/host did around that time
 - Learning: Context from correlated events helps determine true vs false positive
-

Deliverables for Portfolio

1. SIEM Architecture Diagram

Show:

- SIEM server
- Connected endpoints
- Log flow (agent → SIEM)
- Network layout

2. Detection Rule Library

Table format:

Rule Name	Trigger Logic	Data Source	Severity	False Positive Rate	Tuning Notes
-----------	---------------	-------------	----------	---------------------	--------------

3. Five Investigation Reports

For each simulated attack:

- Alert details
- Investigation steps taken
- Timeline reconstruction
- Evidence (log excerpts, screenshots)
- Conclusion
- Recommendations

4. Dashboards

Screenshots of:

- Overview dashboard (total events, alerts over time)

- Failed login attempts by account
- Process execution timeline
- Network connections by destination

5. Lessons Learned Document

- What was harder than expected?
 - How did you tune rules?
 - What would you do differently?
 - Key insights about SOC work
-

Learning Resources

Before Starting:

- Wazuh documentation (complete getting started)
- OR Splunk Fundamentals 1 (free online course)
- "SIEM architecture basics" - any article
- Understand: log collection, parsing, correlation, alerting

During Build:

- Sysmon configuration guide
- Atomic Red Team documentation (for attack simulations)
- Windows Event ID encyclopedia
- MITRE ATT&CK framework

When Stuck:

- Wazuh Google Group / Splunk Answers
 - Reddit: r/blueteamsec
 - Stack Overflow for specific errors
-

Common Pitfalls

Pitfall 1: Not verifying logs are arriving Solution: Before creating rules, confirm SIEM is receiving logs from

all sources

Pitfall 2: Rules too broad (everything alerts) Solution: Add conditions, context, thresholds

Pitfall 3: Not documenting rule logic Solution: Future you won't remember why you wrote it. Document as you go.

Pitfall 4: Skipping investigation practice Solution: Simulating attacks is where real learning happens. Don't rush this.

Pitfall 5: Perfect detection on first try Solution: If you never get false positives, your rules might be too narrow. Iterate.

Self-Assessment Questions

SIEM Basics:

- What's the difference between a log and an alert?
- How do SIEM agents work?
- What's log parsing and why does it matter?

Detection Engineering:

- What makes a good detection rule?
- How do you balance detection vs false positives?
- When would you adjust a rule's threshold?

Investigation:

- What's your process when an alert fires?
- How do you determine if it's a true or false positive?
- What context do you look for?

Practical:

- Your brute force rule is alerting on legitimate lockouts. How do you fix it?
 - You're getting 100 alerts/hour. What do you do?
 - How would you detect lateral movement in your SIEM?
-

Claude Context Instructions

CONTEXT: Project 3 - Home SIEM Lab. I've completed Projects 1 (logs) and 2 (network traffic). Now building a functioning SIEM to tie everything together.

LEARNING OBJECTIVES:

- Deploy and operate a SIEM platform
- Create detection rules for real attacks
- Investigate alerts professionally
- Build SOC analyst workflow skills

MY BACKGROUND:

- Can read logs (Project 1)
- Can analyze network traffic (Project 2)
- Understand basic attack patterns
- Studying Security+ (understand security concepts)

HOW TO HELP:

- ✓ Guide me through SIEM architecture decisions
- ✓ Help me troubleshoot log collection issues
- ✓ Review my detection rule logic before I implement
- ✓ Help me think through investigations systematically
- ✓ Point to relevant documentation
- ✗ Don't give me complete rule configurations
- ✗ Don't solve investigations for me - guide me through the process
- ✗ Don't let me skip rule testing and tuning
- ✗ Don't assume I know SIEM-specific terminology

CURRENT PHASE: [e.g., "Phase 3 - Creating detection rules"]

WHERE I AM: [e.g., "I'm writing a brute force rule but not sure what threshold to use"]

SPECIFIC QUESTION: [Your question]

Progress Checklist

- ☐ Phase 1: SIEM deployed and accessible
- ☐ Phase 2: Agents installed, logs flowing
- ☐ Phase 3: 5 detection rules created
- ☐ Phase 4: 5 attacks simulated and investigated
- ☐ Architecture diagram complete
- ☐ Detection rule library documented
- ☐ Five investigation reports written

- ☐ Dashboards created
- ☐ Lessons learned documented
- ☐ Can answer self-assessment questions

Est. Time: 16-20 hours over 2 weeks

What Success Looks Like

Interviewer: "Tell me about your SIEM experience."

You: "I deployed a Wazuh SIEM in my home lab, configured agents on Windows and Linux endpoints to collect logs including Sysmon telemetry. I wrote five custom detection rules for attacks like brute force, unauthorized account creation, and suspicious PowerShell execution. When creating the brute force rule, I had to tune the threshold because legitimate lockouts were triggering it - I adjusted it to 10 failures in 5 minutes and added logic to ignore service accounts. I then simulated attacks using Atomic Red Team and investigated each alert, documenting my methodology. I can show you my investigation reports and the dashboards I built."

That's comprehensive SIEM experience.